

REQUEST FOR PROPOSAL · BRIEF OF WORK

Request for Proposal

Web Application Vulnerability Assessment and Penetration Testing Engagement

CUSTOMER

SCOPT Analytics

&

PROPOSED SECURITY PARTNER

CyEile Technologies

ENGAGEMENT TYPE

Web Application VAPT

APPLICATION SCOPE

Approximately 25 pages · Approximately 15 APIs

STANDARDS

OWASP Top 10 2025 · API Top 10

STATUS

Draft for RFP / Scope Confirmation

1 Background

SCOPT Analytics intends to engage CyEile Technologies for a professional Vulnerability Assessment and Penetration Testing (VAPT) activity for a web application and associated APIs.

The objective of this engagement is to identify security weaknesses, validate exploitable risks, document findings with practical proof-of-concept evidence, and provide remediation guidance that can be acted upon by the development team.

The engagement is expected to support application security assurance, management review, remediation planning, and a mandatory CERT-In aligned / empanelled report.

2 Application Target

The application target shall be confirmed before the start of testing. Current application scope discussed:

ITEM	DETAILS
Application Type	Web Application with APIs
Web Pages	Approximately 25
APIs	Approximately 15
Access Type	Authenticated login-based access
Testing Environment	UAT preferred; Production only if explicitly approved
UAT Hosting	Hosted on Hostinger
Production Hosting	Hosted on AWS
Credentials	Test credentials to be provided by SCOPT Analytics
Compliance Requirement	CERT-In aligned / empanelled report — mandatory

Final application URL, API endpoints, test user credentials, restricted areas, and approved testing window shall be shared after NDA completion and written authorization.

3 Engagement Objective

CyEile Technologies is expected to perform a controlled and professional VAPT activity covering both automated and manual security validation. The expected outcome is not only a tool-generated report, but a clear, validated, developer-actionable security assessment report containing:

1. Confirmed vulnerabilities.
2. Business and technical impact.
3. Proof-of-concept evidence wherever safe and applicable.
4. Severity and risk rating.
5. Affected URL / API / parameter / role / function.
6. Practical remediation recommendation.
7. Retesting / closure status after fixes are applied.
8. CERT-In aligned / empanelled report (mandatory deliverable).

4 Standards and References

The assessment should be aligned with the following:

1. OWASP Top 10 2025 for Web Application Security.
2. Latest OWASP guidance applicable on the date of testing.
3. OWASP API Security Top 10, wherever APIs are involved.
4. Common web application security testing practices.
5. CERT-In aligned / empanelled reporting expectations (mandatory).

Note: If CyEile Technologies follows any internal testing methodology, checklist, or CERT-In empanelled partner format, the same may be shared as part of the proposal.

5 In-Scope Testing Areas

Testing should cover OWASP Top 10 2025 categories and related risks. The following areas are expected to be covered:

5.1 OWASP WEB APPLICATION TESTING

- Broken access control
- Security misconfiguration
- Software supply chain / vulnerable dependencies
- Injection issues
- Cryptographic failures
- Authentication & session management weaknesses
- Identification & authentication failures
- Integrity & deserialization risks
- Logging, monitoring & visibility gaps
- Server-side request & business logic risks

5.2 ACCESS & AUTHORIZATION

- Horizontal privilege escalation
- Vertical privilege escalation
- Direct URL access to restricted pages
- API access with low-privilege credentials
- IDOR / BOLA style authorization bypass
- Forced browsing
- Role-based UI restriction bypass
- Backend API authorization enforcement

5.3 JWT / SESSION / TOKEN SECURITY

- JWT storage and exposure risks
- Token expiry and refresh behavior
- Token reuse after logout
- Weak token validation
- XSS leading to JWT/session compromise
- Token leakage via storage, logs, URLs or errors

5.4 XSS & CLIENT-SIDE SECURITY

- Reflected, Stored & DOM-based XSS
- Crafted payloads demonstrating realistic impact
- Access to sensitive browser-side data
- JWT/session hijack via insecure storage
- Whether CSP actually mitigates the exploit path

5.5 REACT APPLICATION SPECIFIC CHECKS

- React app shell **200 OK** not reported as a vuln by itself
- Filter false positives from frontend routing
- Manually validate scanner results
- Report build artifacts only if they reveal secrets
- No generic "source code disclosure" without impact

5.6 API SECURITY TESTING

- Broken Object Level Authorization (BOLA)
- Broken Function Level Authorization
- Mass assignment & excessive data exposure
- Improper rate limiting where relevant
- Input validation & parameter tampering
- Authentication bypass
- Error handling & sensitive data leakage
- Endpoint discovery & access control

5.7 KNOWN CVE / DEPENDENCY / CONFIG

- Known CVEs affecting exposed components
- Vulnerable JavaScript packages / dependencies
- Known bypass techniques for identified issues
- Misconfigured headers with actual impact
- Publicly known exploit paths where safe
- Validation on approved UAT unless Production approved

5.8 MANUAL VALIDATION EXPECTATION

- Business logic flaws
- Authorization bypass & role confusion
- Workflow manipulation
- API misuse
- Session & token misuse
- Data exposure through UI/API mismatch

6 Explicitly Out of Scope

The following activities are out of scope unless separately approved in writing:

1. DDoS testing.
2. Stress testing.
3. Load testing.
4. Resource exhaustion testing.
5. Destructive exploitation.
6. Data deletion or modification beyond safe test records.
7. Malware upload or persistence testing.
8. Social engineering.
9. Phishing.
10. Physical security testing.
11. Testing third-party infrastructure not owned or authorized by SCOPT Analytics.
12. Production testing without explicit written approval.

7 Reporting Quality Expectations

SCOPT Analytics expects a high-quality, practical report. The following should be avoided:

1. Pure tool-generated output without manual validation.
2. False positives and false negatives.
3. Reporting React app shell **200 OK** behavior as a vulnerability without impact.
4. Generic CSP observations without proof-of-concept or clear exploit path.
5. Reporting harmless comments in built frontend code unless they disclose sensitive information.
6. Generic low-value recommendations without context.
7. Duplicate findings across multiple URLs without grouping.
8. Reporting informational items as high severity without business impact.
9. Copy-paste OWASP descriptions without application-specific evidence.

For CSP-related findings, **CyEile Technologies** should provide a practical explanation or PoC showing why the CSP weakness matters in this specific application context.

8 Reporting Requirements

The report should include the following minimum sections:

1. Executive Summary.

2. Scope of Assessment.

3. Testing Methodology.

4. Tools Used.

5. Manual Testing Performed.

6. Vulnerability Summary Table.

7. Severity Rating.
8. Detailed Findings.

9. Proof-of-Concept Evidence.

10. Business Impact.

11. Technical Impact.

12. Remediation Recommendation.

13. Retesting Status.

14. Closure Summary.

15. CERT-In aligned / empanelled report section (mandatory).

Each finding should include

FIELD	EXPECTED DETAIL
Finding ID	Unique ID
Title	Clear vulnerability name
Severity	CRITICALHIGHMEDIUMLOWINFORMATIONAL
Affected Asset	URL, API, page, endpoint, role, parameter
Description	Clear issue explanation
Evidence	Screenshot, request/response, payload, safe PoC
Impact	Business and technical impact
Reproduction Steps	Step-by-step validation
Recommendation	Practical fix
Retest Status	Open / Fixed / Risk Accepted / Not Applicable

9 Critical Finding Notification

If any Critical or High severity vulnerability is identified during testing, CyEile Technologies should notify SCOPT Analytics immediately instead of waiting until the final report. Examples include:

1. Authentication bypass.

2. Privilege escalation.

3. Sensitive data exposure.

4. Remote code execution.
5. SQL injection or command injection.

6. Token/session hijacking.

7. Access to restricted data through a lower-privileged user.

8. Any issue materially impacting confidentiality, integrity, or availability.

10 Engagement Timeline

The expected timeline shall start from the engagement date and written authorization.

Day 1	Onboarding, NDA confirmation, authorization, UAT URL sharing, test credentials sharing, and scope confirmation.
Day 2 – Day 3	VAPT activity on the approved target.
Day 4 – Day 5	Initial report submission and remediation by the SCOPT Analytics team.
Day 6 – Day 7	Retesting, closure validation, and CERT-In aligned / empanelled report support.

The above timeline assumes timely access sharing, stable UAT availability, and prompt remediation support from SCOPT Analytics. Any delay caused by access issues, application downtime, environment instability, or delayed fixes may require timeline adjustment.

11 Access and Authorization

SCOPT Analytics shall provide the following before testing begins:

- | | |
|--|--|
| 1. Approved application URL. | 6. Testing date and time window. |
| 2. Approved API base URL / endpoints, wherever applicable. | 7. Emergency contact person. |
| 3. Approved testing environment. | 8. Any restricted functionality or sensitive data areas. |
| 4. Test user credentials. | 9. Written authorization for authenticated testing. |
| 5. User roles for authorization testing. | 10. Written authorization for any high-risk exploit validation, if required. |

No active security testing shall begin without written authorization.

12 Expected Inputs from CyEile Technologies

CyEile Technologies is requested to provide the following in response to this RFP:

1. Confirmation of scope understanding.
2. Proposed testing methodology.
3. Confirmation of OWASP Top 10 2025 and API security coverage.
4. Confirmation of manual testing coverage.
5. Confirmation of CERT-In aligned / empanelled report support (mandatory).
6. Report sample or report structure, if available.
7. Team details / tester profile, if applicable.
8. Confirmation of timeline feasibility.
9. Commercial confirmation.
10. Any assumptions, exclusions, or dependencies.

13 Commercial Terms

The agreed commercial structure is as follows:

ITEM	AMOUNT
Total Professional Fee	₹30,000
Advance Payment (before commencement)	₹15,000
Balance Payment (after report & closure)	₹15,000
GST	Payable extra, as applicable

PAYMENT MILESTONES

1. ₹15,000 advance before commencement of engagement.
2. ₹15,000 after report submission, retesting, and closure support.
3. GST shall be paid by SCOPT Analytics as applicable.

14 Assumptions

- 1. Testing shall be performed on UAT unless Production is explicitly approved.
- 2. SCOPT Analytics shall provide working credentials and required application access.
- 3. CyEile Technologies shall not perform DDoS, stress, load, or destructive testing.
- 4. CyEile Technologies shall maintain confidentiality of all information shared.
- 5. All evidence captured shall be limited to what is necessary for reporting.
- 6. Any customer, user, business, or production data encountered shall not be downloaded, modified, deleted, or shared.
- 7. The final report should be suitable for management review and developer remediation.
- 8. The CERT-In aligned / empanelled report is a mandatory deliverable; any certification dependencies involving a separate empanelled auditor should be clearly communicated.

15 · DELIVERABLES

- 1. Initial VAPT report.
- 2. Detailed technical findings.
- 3. Proof-of-concept evidence.
- 4. Remediation recommendations.
- 5. Retest report / closure report.
- 6. CERT-In aligned / empanelled report (mandatory).
- 7. Final summary for management & compliance record.

16 · ACCEPTANCE CRITERIA

- 1. VAPT activity completed on the approved scope.
- 2. Initial report is submitted.
- 3. Clear remediation guidance is received.
- 4. Retesting is performed after fixes are applied.
- 5. Closure status is documented.
- 6. CERT-In aligned / empanelled report is provided (mandatory).
- 7. Final report is accepted by SCOPT Analytics.

17 Contact and Coordination

SCOPT Analytics shall nominate a technical contact and emergency contact before commencement of testing. CyEile Technologies shall nominate a testing contact responsible for: daily coordination, clarification during testing, critical finding escalation, report submission, retesting coordination, and CERT-In aligned / empanelled report coordination.

18 Confirmation Requested

CyEile Technologies is requested to confirm the following:

- 1. Acceptance of the proposed scope.
- 2. Acceptance of the proposed timeline.
- 3. Acceptance of the commercial terms.
- 4. Confirmation of the mandatory CERT-In aligned / empanelled report.
- 5. Confirmation that testing will be performed in a controlled and non-destructive manner.
- 6. Confirmation that the final report will contain validated findings and not only automated scanner output.

This document serves as a Request for Proposal, scope confirmation, and brief of work. Acknowledgement below indicates acceptance of the scope, timeline, and commercial terms set out herein, subject to NDA completion and written authorization.

FOR CUSTOMER	FOR PROPOSED SECURITY PARTNER
AUTHORIZED SIGNATORY NAME Srinivas G R	AUTHORIZED SIGNATORY NAME
DESIGNATION Co-founder	DESIGNATION
COMPANY NAME SCOPT Analytics	COMPANY NAME CyEile Technologies
SIGNATURE	SIGNATURE
DATE	DATE
SEAL / STAMP	SEAL / STAMP